

BOB-102-round7-remediation

BOB-102 — round-7 remediation of the CM-LAN- ROUTES-AUTHENTICATED gate

Revision: 1 **Last modified:** 2026-08-26T19:48:19Z **Author label:**
(T11/002-user-owned-downloads - milos85vasic - ? - xhigh)

Round-6 verdict remediated: NO-GO — 3 IMPORTANT / 4

MINOR / 3 NIT **Artifacts:** scripts/pre_build/

lan_route_auth_analyzer.py, tests/pre_build/

test_check_cm_lan_routes_authenticated.sh, docs/scripts/

check_cm_lan_routes_authenticated.md (+ .html/.pdf/.docx twins)

0 — The primitive this round fixed was, again, a CLAIM

Round 6 retracted the DROPS-completeness assertion and then wrote a **fresh absolute one column over**: *“every construct able to mark a route protected was audited; the four that leaked are pinned.”* Round 7 falsified it **twice**, in two constructs that same audit had explicitly recorded as *“measured fail-closed”*.

The lesson is the one the DROPS retraction had already recorded: **“audited” is a record of where somebody looked**, and inspection cannot convert that into “there are no others” (§11.4.118). The credit side now carries exactly the form the drop side carries — an **enumerated set**, a **stated method**, an **honest gap** — and each per-construct verdict is a **dated measurement**: *fail-closed* means *measured fail-closed on the shapes tried*, never *cannot leak*.

Rewritten in all four places the absolute lived: the analyzer's METHOD bullet, the analyzer's credit-audit prose, the harness's round-6 section comment, and the guide's *credit-bearing primitive* section (which gains its own boxed retraction beside the round-6 one).

1 — Reproduced before fixed (§11.4.199), then fixed

#	finding	pre-fix measurement	closure
I1	gin group NAME re-bound by a declaration GIN_GROUP cannot see	POST /admin/wipe auth_wired=true, findings 0, exit 0 — wrong path <i>and</i> falsely safe	per-declaration-SITE keying + refusal + credit drop
I1b	the same name bound twice, both resolvable (last-wins)	earlier route inherited the later group, exit 0	ambiguity refusal + len(sites)==1 credit filter
I2	MUX_DECL had no lookbehind: s.mux = http.NewServeMux()	ANY /api/v1/wipe auth_wired=true, findings 0, exit 0	(?<![\w.]) on MUX_DECL
I2b	the return-scan credited through the dot: WithAuth(s.mux)	local mux wrapped by a <i>field</i> mux, exit 0	(?<![\w.]) on the return-scan name match
I3	the router-attribute rule was same-module only	from .routers import router + router.post("/wipe") (wipe) → route vanished , findings 0, exit 0	owner resolved transitively through imports
M1	gomux composite-literal receiver was a SILENT DROP	Server{}.mux.HandleFunc(...) absent from the inventory, exit 0	dotted check keys on a preceding dot, not a character allowlist
N2	gin composite-literal receiver refused under the wrong label	refused as “ <i>path is not a string literal</i> ” — untrue of that line	same primitive; F8 class, second instance
M4	_carriers recorded as fail-closed	stats := describe(mux); WithAuth(stats) → auth_wired=true	behaviour unchanged ; the boundary is

#	finding	pre-fix measurement	closure
			now owned and pinned

I1, I2, I3, M1 are false attributions of SAFETY or silent drops on unauthenticated mutating LAN routes. Every one was reproduced against the shipped analyzer before being called a defect.

2 — The primitive, stated once and applied to every door (§11.4.250)

Three of this round's fixes are the SAME defect in three places, and in two of them the defective thing was an **enumerated allowlist**:

- MUX_DOTTED_OWNER / GIN_DOTTED_OWNER led with `[\w)\]]` — a list of “characters a Go expression may end with”. `}` was not in it. The condition that was ever load-bearing is *the receiver is reached through a selector*, i.e. **preceded by a dot**; the `verb+(` pair is what keeps a dotted handler argument out, not the leading class.
- `groups` was name-keyed and file-scoped, so an unresolvable declaration re-bound a name **invisibly**. Counted per declaration SITE now — the rule already applied to gin engines (A2) and FastAPI routers (A3).
- the router-attribute rule asked “*did THIS module declare it?*”, so it was one import away from being bypassed. The engine already resolved imports for guard aliases and for mounts; same-module keying was an omission.

3 — §1.1 mutation matrix (against byte-verified scratch copies)

Kill direction — every new rule is load-bearing:

MU-2	return-scan LEADING lookbehind removed	KILLED	gomux-dotted-return-false-safe
MU-3	return-scan TRAILING <code>\b</code> removed (X1)	KILLED	gomux-return-prefix-not-credit
MU-1	MUX_DECL lookbehind removed	SURVIVED	alone ->
	EQUIVALENT behind MU-2		
MU-1+MU-2	combined	KILLED	gomux-dotted-decl-false-safe (+1)
MU-4	MUX_DOTTED_OWNER allowlist restored	KILLED	gomux-complit-receiver-refused
MU-5	GIN_DOTTED_OWNER allowlist restored	KILLED	complit-

label diagnostic		
MU-6a group ambiguity out + last-wins back rebound-false-safe	KILLED	gin-group-
MU-7 ambiguity REFUSAL removed ambiguity-label diagnostic	KILLED	group-
MU-8 unresolvable-group REFUSAL removed rebind-label diagnostic	KILLED	group-
MU-9 _router_key back to same-module imported-router-call	KILLED	fastapi-
MU-10 drop `mount` unmodelled-mount	KILLED	fastapi-
MU-11 drop `add_route` unmodelled-add-route	KILLED	fastapi-
MU-12 kill exemption class validation bad-class	KILLED	exemption-
MU-13 drop the *_test.go FILTER gomux-test-file-skipped	KILLED	gin- +

False-positive direction (§11.4.201(1)) — every guard is RED-capable both ways:

G-1 ambiguity fires on ANY group name inherit + gin-two-groups-distinct-ok	KILLED	gin-group-
G-2 _router_key drops owner qualification imported-nonrouter-quiet	KILLED	fastapi-
G-3 group credit dropped entirely inherit (+1)	KILLED	gin-group-
G-4 MUX_DOTTED_OWNER over-broad fixtures	KILLED	x14
G-5 GIN_DOTTED_OWNER over-broad handler-ok (+1)	KILLED	gin-dotted-
G-6 GIN_GROUP_DECL over-broad (any assignment) decl-semicolon	KILLED	gin-group-

Round-5/6 pins re-verified against the new regexes (they could have become equivalent):

R6-M2 GIN_USE lookahead removed use-false-safe	KILLED	gin-dotted-
R6-M4 gomux dotted refusal removed dotted-recv-false-safe (+1)	KILLED	gomux-
R5 GIN_ROUTE lookahead removed EQUIVALENT (see §4)	SURVIVED	alone ->
R5 + gin dotted refusal removed owner-false-safe (+1)	KILLED	gin-dotted-

4 — Found this round, not reported by the review

The gin twin of round-6’s proven-equivalent M3. Round 6 measured that MUX_ROUTE’s lookbehind is unreachable behind MUX_DOTTED_OWNER and recorded it as an equivalent mutant. **Nobody measured the gin twin.** GIN_ROUTE’s lookbehind is in exactly the same position: GIN_DOTTED_OWNER refuses and continues first, so removing the lookbehind alone leaves all 115 fixtures green, while removing **both** kills gin-dotted-owner-false-safe. The pair is load-bearing as a unit. Recorded beside GIN_ROUTE so a future reader does not delete it as dead code — a surviving single mutation is not evidence of redundancy.

A live corroboration of the NIT-1 gap, mid-session. At 21:40, concurrent BOB-204 work created an untracked qBitTorrent-go/internal/jackettapi/bob204_failclosed_test.go — **inside a scanned policy root.** The *_test.go FILTER is what kept it out of the route inventory, and until this round that filter had **no fixture in either Go extractor.** The scan-list digest and the --json md5 are byte-identical precisely because that filter works; before this round nothing held it to it.

5 — The two moved digits, explained rather than absorbed

digit	round 6	round 7	cause
non-vendor .go census	106	107	the foreign untracked BOB-204 test file above
residue-gate scan	272 files	273	the same one file

Attributed by controlled experiment, not by inference: moving that single file aside returns the census to **106** and the residue gate to scanned 272 file(s); 0 hit(s); 1 audited waiver(s); restoring it returns both. Neither delta is attributable to this round’s changes, and the digits that would have moved *if* they were are all byte-identical (below).

6 — Do-not-regress (all re-run this round)

harness 115 passed, 0 failed (was 93; +22 fixtures) x3 deterministic,

```

byte-identical stdout, verdict-stream sha
8030fee6400991ac (was 2794ed7597175549 at 93)
real tree 74 routes / 3 services / 23 known-gaps /
PASS, exit 0, stderr 0 bytes UNCHANGED
real tree --json md5
ecd4b31c2f40c87ed321a00c43cacb26
UNCHANGED
scan list 19 paths (8 .py + 11 .go), sha256 head
c7a793a0021c3804 UNCHANGED
go lexical census 107 files, 0 lex gaps, 0 odd separators,
control needle proven seeing
(106 excluding the foreign BOB-204 file –
see §5)
py_compile CLEAN under -W error::SyntaxWarning
bash -n CLEAN (gate + harness)
residue gate scanned 273 file(s); 0 hit(s); 1 audited
waiver(s); exit 0
(272 excluding the foreign file; the
waiver is a SIBLING gate's, unchanged)
guide twins .html/.pdf/.docx regenerated, mtimes
strictly after .md,
0 mojibake, needles § x26 / – x66, round-7
retraction present in the PDF

```

7 — Not closed / honestly open

- **The `_carriers` over-approximation is fail-OPEN and is KEPT.** stats := describe(mux) + return WithAuth(stats) credits mux. The behaviour is unchanged by design — the alternative is a Go return-value model, a second parser with its own failure modes — and it is now owned in `_carriers`, in the skip table and in the guide, and pinned by `gomux-carrier-over-approximates` so a future narrowing is deliberate.
- **The gate still asserts static WIRING, never runtime ARMING.** BOBA_API_TOKEN unset ⇒ statically-protected routes are open on a default deploy. Tracked as **BOB-197**. Unchanged, not claimed covered.
- **fastapi module-basename collision** is measured fail-closed but incidental; the note now lives beside the guard-alias rule that produces the refusal, not only in a round-6 evidence file.
- **uses remains file-scoped across functions.** gin-one-engine-two-funcs pins that a .Use in one function credits a route in another — an over-approximation the harness deliberately enshrines. Full function-scoping would close it and would flip that green fixture, so it is an operator-owned change, recorded here rather than made silently.
- **The enumerated set is a sample, not a proof** — on the credit side now too.

- `pre_build_verification.sh` was NOT run — the conductor owns it.